

Home > Gotopia Articles > The Rush to Adop...

The Rush to Adopt AI: Business Risks & How to Get it Right

Sarah Wells & Nick Selby: AI tools need access to your crown jewels to be useful - so what's your blast radius when it goes wrong? Read the conversation.

Share on:     

About the experts



Nick Selby (EXPERT)
Managing Partner, EPSD



Sarah Wells (INTERVIEWER)
Independent Consultant & Author of "Enabling Microservice Success"

Read further



The Problem Nobody Is Talking About

Sarah Wells: We're going to talk about something that came up when I was writing my talk for GoTo Copenhagen this year — a talk about governance and how to reduce risk without slowing people down. When I was thinking through the examples, so many of them were related to AI implementations. We've both been working across security engineering and it's something we've really noticed in the last year. I wanted to talk about the current rush to adopt AI and why that introduces significant business risk.

My background: I'm an independent consultant. I generally work to help organisations improve their engineering effectiveness — making sure you have platforms and processes in place for delivering business value.

Nick Selby: I'm a managing partner at a company called EPSD — it doesn't stand for anything. It's a group of independent consultants who got together to address the strategic issues around information technology adoption. One of the things we've consistently noticed in our consulting lives is that executives will be frustrated or confused about performance issues. They'll say, "I thought we bought the best stuff — didn't we take care of that by going to X platform?" Meanwhile, the engineering teams being talked about are thinking, "Well, if you would stop pivoting, maybe we could get things done." There is a huge chasm between how these groups communicate, and that happens to be what we work on.

Sarah Wells: Whenever you talk to people about the problem — that engineering teams aren't delivering as much value as quickly as expected — you go and talk to the engineering team, and first of all, they absolutely know where the problems are. But secondly, it's very rarely actually an engineering problem. It's "we don't actually know what the direction is — after two years, we still don't know where we're going." Or "we're being asked to spend no time on technical debt and keeping things up to date, and you just get slower and slower." That's been an interesting pattern for a few years. What's making it even more interesting now is the rush to AI.

Nick Selby: Absolutely. And when executives say, "it's our engineering," they expect a technical response — but the answer is usually a strategic or programmatic one at heart. Because we've already framed it as an engineering or technical problem, it further obfuscates the issue.

How AI Vendors Are Blurring the Language of Risk

Sarah Wells: You were writing about a change in the terminology people are using when they talk about AI.

Nick Selby: Yes. This comes from **Heidy Khlaaf** over at the AI Now Institute. What they've recognised is a tendency within the AI industry to repurpose existing terminology — phrases like "vulnerability management," "safety," or "red teaming" — but use them to describe totally different things.

For example, your general counsel might hear "health and safety issues inside AI" and think, "Oh yes, that's typical product liability language — I know this territory." They would be completely wrong. What AI companies are actually talking about when they use those terms is something like: "Our AI chatbot won't tell you how to make a TATP bomb." That is genuinely confusing to anyone who isn't paying very close attention.

The Data Access Problem

Sarah Wells: There are a couple of interesting aspects about AI tools that everyone's trying out. First, the companies building AI tools are very keen — they have a fear of missing out, and they need to get products out now. And we all know that when you're rushing to ship, security can slip. Are we sure MFA is on GitHub accounts? There's a whole load of baseline stuff that, as someone helping companies adopt a tool, you'd expect to be in place.

The second aspect is that to be valuable, AI tools very often need access to the crown jewels of your company's data. They're integrated with Salesforce, with Slack, with your Google Workspace. It feels hugely risky — and yet there's enormous pressure to say yes. So what do you actually have to do to make it safe to adopt?

Nick Selby: The tendency, especially in Silicon Valley, is to push things out really quickly without thinking through safety. When Apple Maps first came out, remember how many screenshots there were of destinations in the middle of a lake? That was a safety issue — if you're following turn-by-turn directions and it turns you into a wall, that's a terrible product introduction.

Let me pay real respect first to the fact that CEOs are under extraordinary pressure from investors, boards, and their peer group to be adopting AI and using it to change fundamentals — not just in the final product, but in everything: accounts payable, tracking, internal tooling. There's a lot of pressure to show you're doing it so you can claim competitiveness.

You and I worked together at a customer that was caught up in the Drift/SalesLoft breach. I was stunned listening to their head of revenue talk about Drift — for me it was an information security nightmare with unlimited blast radius, but the revenue person saw it as the single greatest channel for high-intent purchase they had. A chatbot on the main page of the website that asks two questions — what country,

what size organisation — and books three appointments with a salesperson. A genuine game-changer.

But to do that, Drift needed access to Salesforce, to Google Workspace calendars, to some HR data to understand whose role was what and where salespeople had their territories. When you start thinking about what it needs for such a simple task — just to set an appointment — it's an extraordinary amount of your most radioactive data.

Sarah Wells: And it's quite difficult to know exactly what's been turned on, because these things have so many integrations. Even individual users granting access to their personal Google Calendar — you have to be really sure those people granted only the minimum necessary access. This is a huge challenge.

Nick Selby: It's a huge challenge even if you write everything down. Even if you talk to all the people involved and understand the choices they're making. And what I've found in the last year — across our customers and talking to colleagues across their organisations — is that nobody is actually doing that part.

The pressure is so heavy on CEOs to adopt that it's very likely someone will walk into the office on a given Tuesday and say, "That's it — we've got to have AI." So what we're seeing is that people are not asking: what are the goals of this particular AI tool we're thinking of implementing? What do we want it to do? What do we *not* want it to do?

They're not thinking about what data it needs to do that — let alone the minimum data. And remember: the first product requirement if you're selling an AI tool is that you need to be able to ingest data from anywhere, at any time. These tools are extraordinarily good at finding ways into data repositories.

There's also a network effect. As soon as one user grants personal account access, the AI tool can ingest not just that user's data, but everything that's been shared with that user — which may have been shared with others in turn. It gets insidious and grows quickly.

Sarah Wells: There are a lot of things you needed to do anyway that AI just exacerbates. You really need to know what you've got in your estate, what's been turned on, and what it grants access to.

Defining the Blast Radius Before Something Goes Wrong

Sarah Wells: That matters even more when so many things are being connected up and accessing your data. I wouldn't expect any organisation to have a diagram

showing exactly which integrations have been enabled — more likely you find out through an incident: "Oh, I didn't realise it was also connected to that."

Nick Selby: Yes, you are absolutely going to find it that way. We've had clients with several AI-related incidents, and what they discover is that the blast radius is much larger than most people anticipate.

Here's the other critical difference from traditional enterprise tools: even Salesforce — figuring out what's actually connected to your Salesforce cloud is genuinely complex. But typically, if it's not an AI tool, it's not doing it super fast and aggressively. What many CEOs, CTOs, and CFOs are thinking is: "It's OpenAI, it's Anthropic — these are big companies, this is enterprise software, surely it's not that different from Salesforce or Google Workspace or Slack or Atlassian."

But it really is different. If you look at the most devastating AI-related security incidents in the last two years — with a clear acceleration this year — criminal gangs and attackers are finding that the basic information security posture within these AI products is failing in quite spectacular fashion, at the most fundamental levels we would expect from any enterprise software vendor.

What Good AI Governance Actually Looks Like

Sarah Wells: What advice would you give to people working in security engineering or security more broadly — people who don't want to just be the team that says no, but are facing something genuinely scary heading towards them?

Nick Selby: The first thing I'd say is: don't look at this as a security issue. This is an information technology issue. The knowledge areas are deep and rich within IT, whereas security tends to be treated as "we'll fix that, we've got that covered, don't worry" — and that's really not how this goes.

This actually begins with business strategy. Sit down with a cross-disciplinary group and say: this tool sounds like it has a great upside. We'd like some of that. So now — what's the minimum amount of information it needs to do this task we think is so valuable? What data does it actually need, and where does that data live? Most enterprises have data in a lot of different places, so mapping this out is genuinely important work. That mapping is what helps you define the blast radius.

Then ask: when this goes wrong, what do we lose? What's the worst that can happen? If the answer is, "this thing has administrative access to Salesforce, Atlassian, Slack, and Microsoft 365 mail simultaneously" — well, that's a lot that can go wrong at once.

From there you work on reducing permissions to the absolute bare minimum, making sure that configuration won't drift over time — now you're into monitoring —

and making sure you know when something changes. Because when something does go wrong, things move very fast.

A couple of weeks ago there was an AI integration breach, and we saw the hack come through threat intelligence channels at around noon Eastern time. The official notification from the company came at around 6 p.m. Eastern. Six hours. You need your own telemetry so you've identified what the thing is supposed to do, where it's supposed to get its data, you've brought permissions to the minimum allowable, you've monitored for configuration drift, and you've set the alarms so that if something unexpected happens, the team knows immediately.

Sarah Wells: There's also the element of being prepared for incident response. The second time you go through something, you're much better — because you know how to quickly disable integrations, who needs to be involved, what the steps are. Just like any incident management: if you haven't thought it through and practised it, it takes a long time to get going. Having a clear answer to "who do we call, and what do we do — which generally means disabling things" is critical.

Nick Selby: Ideally you disable things temporarily before it gets blown up entirely. And what we've described requires involvement across sales and revenue, IT maintenance, product development, traditional engineering, information security, and support teams. None of those teams, on their own, has all the information needed to make good decisions in advance about defining and reducing the blast radius.

Your revenue people are going to be saying "that was terrible — when can we turn it back on?" Your security team is going to want more caution before the switch goes back. What you really need is a business structure that constantly balances risk versus benefit — before, during, and after any incident — so that you don't make the same mistake again.

Threat Modelling as Starting Point for Executive Conversations

Sarah Wells: One thing I've really valued working with you on recently is threat modelling — not an area I've primarily worked in — and in particular how you present it to executives. The core message being: the only people who can accept risk is you. We can explain what the risks are, but you have to own the decision. In one engagement, that led to a clear decision: "We're not going to integrate with this part of our estate, because the risk isn't worth the reward."

Nick Selby: It's an interesting moment when that happens, especially with aggressive companies. But the threat model is the right place to start — not

because it will be perfectly accurate about every threat, but because it forces real-world grounding.

For those who haven't done a threat modelling exercise: you look at things that can go wrong and put them into categories — repudiation, spoofing, and so on. But the most important outcome isn't getting every threat exactly right. It's finding real-world examples of how risks that executives are considering leaving open or unaddressed can be exploited — by attackers or by trusted third parties. Supply chain risk is really what's at the heart of all of this.

Identify the threats, tie them to the risks that would enable exploitation, and then translate back into traditional risk language — likelihood and impact — which executives understand. In one or two meetings of listening to threat models framed that way, executives will start connecting the dots very quickly.

And that's why it's so useful: your security team doesn't accept risk on behalf of the company. You do. The security team's job is to explain those risks in language that executives can actually understand.

Sarah Wells: That is genuinely powerful. Likelihood combined with impact — anyone can hold those two variables and think, "This one is very unlikely but catastrophic; this one is very likely but manageable." That's a framework anyone can work with.

Conclusion

So I think the wrap-up point is: it's exactly the same stuff you ought to be doing anyway — but suddenly there's an explosion of potential tools, everyone wants to try things, and you're assessing large numbers of different options simultaneously. For a security engineering team, part of the challenge is just handling the volume of requests: "Can I try this thing out?"

Nick Selby: You have to be systematic about it. All your support teams — legal, information security, IT, whoever manages third-party tools — all have to be involved. It really is a return to fundamentals. What can go wrong in traditional enterprise IT?

Some of the things you can do with MCP servers — Model Context Protocol — are genuinely wonderful. But in a number of code audits we've done, the AI functionality worked perfectly. The problem was that they were using old libraries, hadn't patched anything, and even brand new out of the box, they were already vulnerable.

Think of a vastly larger and more exploitable attack surface than you've ever seen before. And because of these tools' propensity to gather as much data as they can,

think of data like water — it seeps into absolutely everything. What in your organisation is not watertight? These are the questions to ask before you turn things on.

And before you even ask those questions, the teams that will be having these conversations — legal, IT, security — need to define their terms, make their policies, and be prepared to adapt them regularly. This industry and these technologies are moving very quickly.

Sarah Wells: I think that's a great place to wrap up. This has been a really interesting discussion, Nick.

Nick Selby: It really is all of enterprise IT in one concentrated area. It tends to focus the mind.

Watch Next



gotopia



Events



NOVEMBER 2025



Beyond the Hype: Real Talk on AI-Assisted Development

MARCH 2025



Concerto for Java and AI - Building Production-Ready LLM Applications

DECEMBER 2024

goto;

ALEX CASTROUNIS

Large Language Models

Large Language Models: Friend, Foe, or Otherwise

MAY 2023



[Privacy policy](#)



© 2026 Trifork